GUION OFICIAL DE EXPOSICIÓN — 5 INTEGRANTES

AuditPIMS 2.0: Agente de Evidencia y Auditoría de Sistemas

Curso: Auditoría de Sistemas (UNSA 2026) | Docente: Edward Vicente Zarate Carlos

Grupo 4: Bernahola Vilca, Contreras Huamani, Soncco Mamani, Velasque Arcos, Quispe Madariaga

REGLA DE ORO DE PRESENTACIÓN (Show me the code):
• CERO diapositivas de texto aburrido en PowerPoint. Toda la exposición se apoya en el Dashboard Web en vivo (http://localhost:8000) y el repositorio público en GitHub (https://github.com/Piero-design/AuditPIMS).
• Tiempo total estricto: 6:00 minutos (1:10 min por integrante aprox). Mantener sincronización fluida.

PARTE 1. INTEGRANTE 1 — Introducción, Problema y Rol en el Salón — Tiempo: 1:10 min

[QUÉ PROYECTAR EN PANTALLA]: Proyectar la página principal del Dashboard Web (http://localhost:8000) o el README de GitHub.

"Buenos días profesor, buenos días compañeros. Somos el Grupo 4 y presentamos nuestro proyecto: AuditPIMS 2.0: Agente de Evidencia y Auditoría de Sistemas.

En la implementación de un Sistema de Gestión de Privacidad de la Información (PIMS), el mayor dolor de cabeza no es redactar políticas en un papel, sino demostrar con evidencias objetivas que esos controles se cumplen en el día a día sin caer en subjetividades humanas.

Tradicionalmente, la auditoría se hace de forma manual, lenta y fatigante: un auditor tarda días revisando contratos, y suele cometer errores graves como asumir que si un documento dice 'cumplimos el RGPD en 72 horas' está bien, desconociendo la ley peruana.

En el ecosistema multiagente de este curso, nuestro grupo cumple el rol de Agente Juez y Auditor Interno: nuestro sistema está diseñado para auditar y emitir dictámenes periciales sobre los artefactos que produzcan los otros 7 grupos del salón."

-> Pase de voz: A continuación, mi compañero [Nombre Integrante 2] detallará el marco normativo estricto del agente.

PARTE 2. INTEGRANTE 2 — Marco Normativo Dual (ISO 27701 y D.S. 016-2024-JUS) — Tiempo: 1:10 min

[QUÉ PROYECTAR EN PANTALLA]: Señalar en el encabezado del Dashboard los badges normativos (ISO 27701:2025 y Ley 29733 - 48h).

"Gracias. Para garantizar rigor técnico y legal, nuestro agente se fundamenta en dos marcos vigentes:

1. ISO/IEC 27701:2025 (2.ª edición): Cuya principal revolución técnica es que ahora es un estándar completamente independiente y certificable por sí mismo, sin requerir previamente ISO 27001. Nuestro agente tiene estructurados sus 52 controles para Responsables (RT) y Encargados (EN) del tratamiento.

2. El Marco Legal Peruano: La Ley N.º 29733 y su nuevo Reglamento aprobado mediante el D.S. N.º 016-2024-JUS, vigente desde marzo de 2025.

Aquí el agente aplica una regla de negocio crítica: muchas organizaciones copian plantillas europeas del RGPD que dan 72 horas para notificar fugas de datos. En el Perú, el nuevo reglamento exige de forma perentoria un plazo máximo de 48 horas ante la ANPDP. Si el agente detecta que un procedimiento fija 72 horas, dictamina automáticamente una No Conformidad Mayor."

-> Pase de voz: Doy el pase a mi compañero [Nombre Integrante 3] para explicar la arquitectura técnica de software.

PARTE 3. INTEGRANTE 3 — Arquitectura, Criptografía SHA-256 y la Skill — Tiempo: 1:10 min

[QUÉ PROYECTAR EN PANTALLA]: Proyectar el Diagrama de Arquitectura en Capas en GitHub o la carpeta 'auditoria-evidencias-pims'.

"Gracias. El reto técnico de este Hito fue pasar de un prompt improvisado de ChatGPT a una arquitectura de software agéntica y reutilizable, sustentada en tres componentes:

1. Cadena de Custodia Criptográfica (SHA-256): Antes de que un documento pase a la IA, el sistema ejecuta código Python para calcular el hash criptográfico SHA-256 del archivo físico en memoria. Esto garantiza la integridad y el no repudio que exige el Control A.3.14 de ISO 27701; si la evidencia es alterada un solo byte, la auditoría lo detecta.

2. La Skill Modular (auditoria-evidencias-pims): Contiene los 52 controles y evalúa las evidencias aplicando de manera paramétrica los 6 criterios formales de auditoría de ISO 19011:2018: Pertinencia, Suficiencia, Vigencia, Aprobación, Trazabilidad y Completitud.

3. Motor de IA Agnóstico: Nuestro backend en FastAPI puede conectarse a modelos en la nube como Gemini, o conectarse localmente a las GPUs del laboratorio de la universidad vía Ollama, garantizando soberanía de datos y confidencialidad total."

-> Pase de voz: Siguiendo el principio de 'Talk is cheap. Show me the code', mi compañero Piero realizará la demo en vivo.

PARTE 4. INTEGRANTE 4 (Piero Bernahola) — Demostración en Vivo en el Dashboa — Tiempo: 1:30 min

[QUÉ PROYECTAR EN PANTALLA]: Tener abierto http://localhost:8000 en el navegador. Realizar la carga y clic en vivo.

"Gracias. Como pueden ver en pantalla, este es el Dashboard de AuditPIMS 2.0, desarrollado en FastAPI con una interfaz ejecutiva cálida en tonos blanco y ámbar, diseñada para auditoría formal.

(Acción: Seleccionar el Contrato Telecall en el menú)
Vamos a auditar en vivo el Contrato de Locación de Servicios con Telecall Perú S.A. Observen cómo en la esquina inferior izquierda el sistema ya calculó su huella digital criptográfica SHA-256 (0748853a...). La evidencia queda sellada.

(Acción: Clic en el botón naranja 'Evaluar con IA Agéntica')
Presionamos 'Evaluar'. En menos de 2 segundos, el agente cotejó el contrato contra la Skill y la legislación peruana:
• Dictaminó automáticamente: NO CONFORMIDAD MAYOR.
• En la cuadrícula superior evaluó los 6 criterios de ISO 19011: marcó Aprobación = NO, porque el contrato tiene las líneas de firma en blanco; es un borrador no perfeccionado.
• Detectó que no existe un Acuerdo de Tratamiento de Datos (DPA) formal y que la confidencialidad solo protegía tarifas comerciales, dejando totalmente desprotegidos los datos de los alumnos y postulantes.
• Cita textualmente las desviaciones y emite recomendaciones de mitigación inmediatas."

-> Pase de voz: Le doy el pase a mi compañero [Nombre Integrante 5] para explicar la gobernanza y la integración multiagente.

PARTE 5. INTEGRANTE 5 — Gobernanza HITL, Protocolo Multiagente y Cierre — Tiempo: 1:10 min

[QUÉ PROYECTAR EN PANTALLA]: Piero hace clic en 'Validar & Firmar', luego cambia a pestaña 'Matriz SOA' y muestra '/docs'.

"Gracias. Un principio ético y técnico fundamental de nuestro sistema es la gobernanza Human-in-the-Loop (HITL):

La Inteligencia Artificial realiza el triaje exhaustivo y propone el hallazgo, pero la validez legal siempre requiere supervisión humana. Como ven en pantalla, el Auditor Líder presiona el botón 'Validar & Firmar (HITL)', sellando electrónicamente el dictamen aprobado.

(Piero cambia a la pestaña 'Matriz SOA')
En el Modo M3, todos los hallazgos alimentan automáticamente la Matriz de Aplicabilidad (SOA) con los 52 controles, calculando la tasa de cumplimiento del PIMS en tiempo real.

(Piero cambia a la pestaña 'Integración Multiagente' o abre /docs)
Por último, para integrarnos con los otros 7 grupos del salón, tenemos expuesto el endpoint POST /api/auditar y la documentación interactiva Swagger. Cualquier grupo puede enviarnos un documento en formato JSON y nuestro agente le devolverá el dictamen pericial estructurado en segundos.

Todo el código fuente y las pruebas están disponibles públicamente en nuestro repositorio de GitHub. Muchas gracias profesor, quedamos listos para sus preguntas."

BANCO DE PREGUNTAS TRAMPA DEL DOCENTE (Y CÓMO RESPONDER)

[?] Pregunta 1: ¿Por qué no usar simplemente ChatGPT o NotebookLM en lugar de programar esto?

Respuesta blindada: NotebookLM es una herramienta pasiva de lectura sin herramientas digitales. Nuestro agente es un sistema de software activo: calcula hashes SHA-256 para custodia pericial (A.3.14), aplica reglas deterministas bajo ISO 19011 (sin alucinaciones complacientes), expone una API REST para conectarse con los otros 7 grupos y guarda trazabilidad para auditoría continua en producción.

[?] Pregunta 2: ¿Por qué crearon identificadores propios como CL-04, RT-15, SG-04 y no los números exactos de la norma?

Respuesta blindada: Por respeto al copyright internacional de la norma ISO/IEC 27701:2025 y por claridad arquitectónica: agrupamos los controles por roles funcionales de auditoría: CL para Cláusulas del sistema, RT para Responsables del tratamiento, EN para Encargados y SG para Seguridad compartida.

[?] Pregunta 3: ¿La Inteligencia Artificial va a reemplazar al auditor humano?

Respuesta blindada: No. Nuestro diseño se rige estrictamente por el principio Human-in-the-Loop (HITL). La IA procesa en segundos los 52 controles y detecta faltantes con precisión, pero la aprobación final, la calificación de severidad y la emisión del dictamen oficial siempre las valida y firma el auditor humano desde el panel.

[?] Pregunta 4: ¿Por qué afirman que un procedimiento con 72 horas es una No Conformidad Mayor?

Respuesta blindada: Porque bajo el D.S. N.º 016-2024-JUS (nuevo reglamento de la Ley 29733 vigente desde marzo 2025), el plazo legal imperativo en el Perú para notificar brechas de seguridad a la ANPDP es de 48 horas. Las 72 horas corresponden al RGPD europeo. Copiar normas foráneas en territorio peruano expone a la empresa a multas graves de la autoridad.

[?] Pregunta 5: ¿Dónde podemos revisar el código y los endpoints de su agente?

Respuesta blindada: El proyecto está publicado como código abierto en GitHub: https://github.com/Piero-design/AuditPIMS con licencia académica, y los endpoints REST interactivos están documentados bajo estándar OpenAPI Swagger en /docs.